

LAB: FILE PATH TRAVERSAL

TRAVERSAL SEQUENCES
STRIPPED WITH
SUPERFLUOUS URL-DECODE

CNO IV: Seguridad Informática

Fabiola Calvillo Galván 182455

Mtro. Servando López Contreras

LABORATORIO: FILE PATH TRAVERSAL TRAVERSAL SEQUENCES STRIPPED WITH SUPERFLUOUS URL-DECODE

Introducción

Nombre del laboratorio: File Path Traversal: Traversal Sequences Stripped with Superfluous URL-Decode

Nivel del Laboratorio: Practitioner

Tipo de explotación: Path Traversal (Directory Traversal) mediante doble codificación URL (Double URL Encoding). La vulnerabilidad corresponde principalmente a CWE-22, ya que permite acceder a archivos fuera del directorio previsto.

Objetivo del laboratorio

El objetivo es evadir el filtro de secuencias de Path Traversal de la aplicación y conseguir que el servidor interprete una ruta que permita acceder al archivo: **/etc/passwd**

El laboratorio indica que la vulnerabilidad se encuentra en la funcionalidad que muestra las imágenes de los productos.

Explicación Técnica de la Explotación

La aplicación intenta bloquear las secuencias de Path Traversal, principalmente: **../**

El problema está en el orden de procesamiento:

1. La aplicación recibe el parámetro filename.
2. Primero realiza la comprobación para bloquear las secuencias de traversal.
3. Posteriormente realiza un URL-decode.
4. Debido a esto, podemos enviar la secuencia codificada dos veces.
5. La primera decodificación convierte **%25** en **%**.
6. La segunda decodificación convierte **%2f** en **/**.
7. Finalmente, el servidor termina interpretando **../**, permitiendo salir del directorio de imágenes y acceder a **/etc/passwd**.

Por ejemplo:

../%252f se procesa aproximadamente así: **../%252f** primera decodificación **../%2f** segunda decodificación **../** . Por eso el filtro no detecta inicialmente la secuencia **../**.

Explotación

Primero se identifica una petición de imagen similar a: **GET /image?filename=36.jpg HTTP/1.1**

El parámetro vulnerable es: **filename**

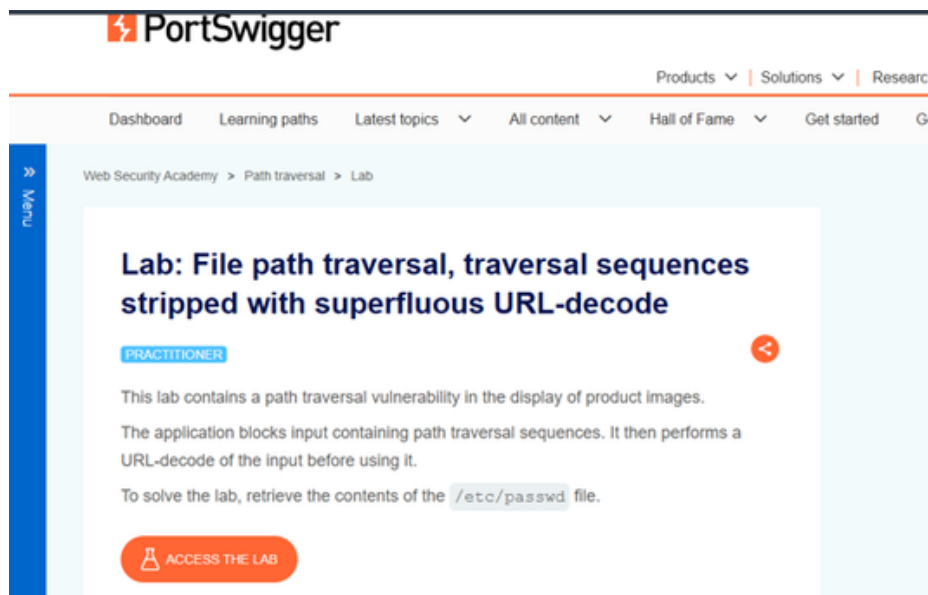
En Burp Suite Repeater, se modifica su valor utilizando doble URL encoding: **../%252f../%252f../%252fetc/passwd**

Por lo tanto, la petición queda conceptualmente: **GET /image?filename=../%252f../%252f../%252fetc/passwd HTTP/2**

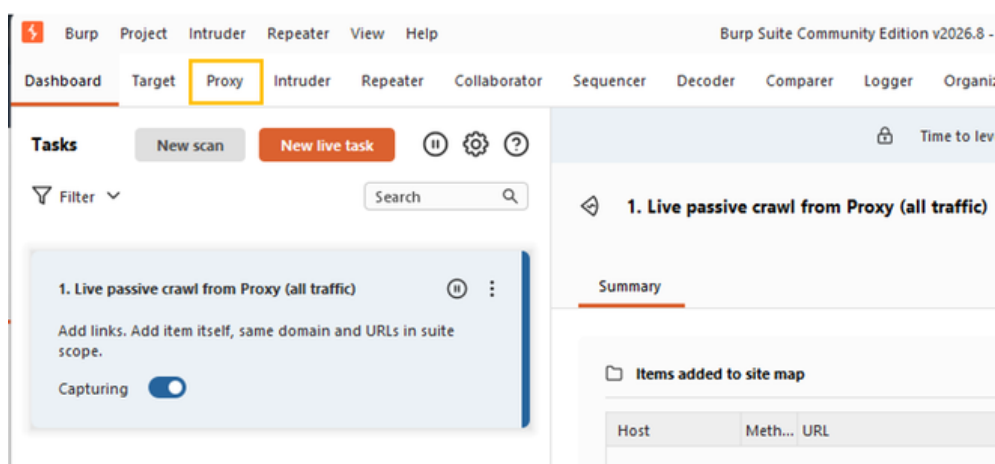
Al procesarse las dos decodificaciones, el servidor termina interpretando: **../..../etc/passwd** y devuelve el contenido del archivo solicitado.

Procedimiento paso a paso

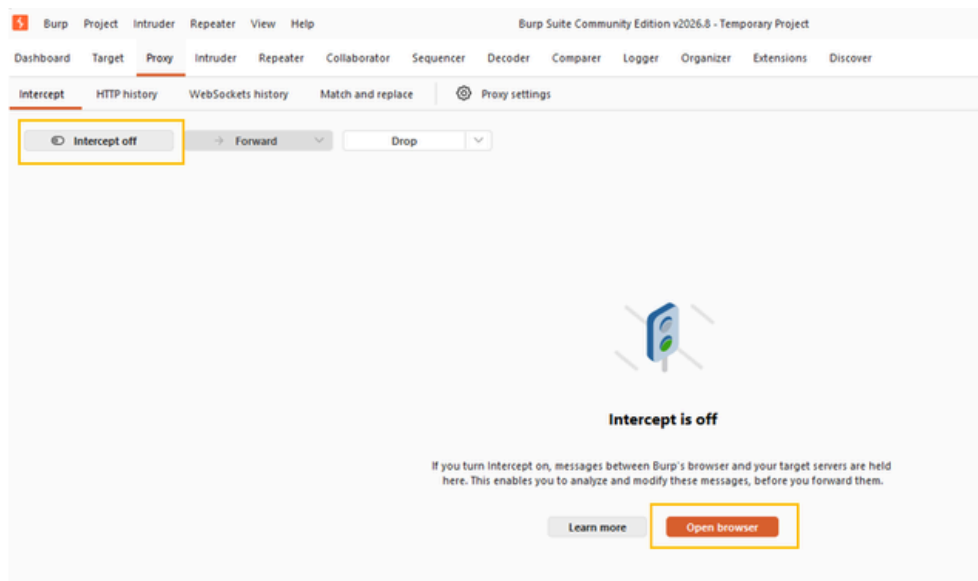
Primero deberemos acceder a la página en donde podremos ingresar a nuestra práctica de laboratorio.



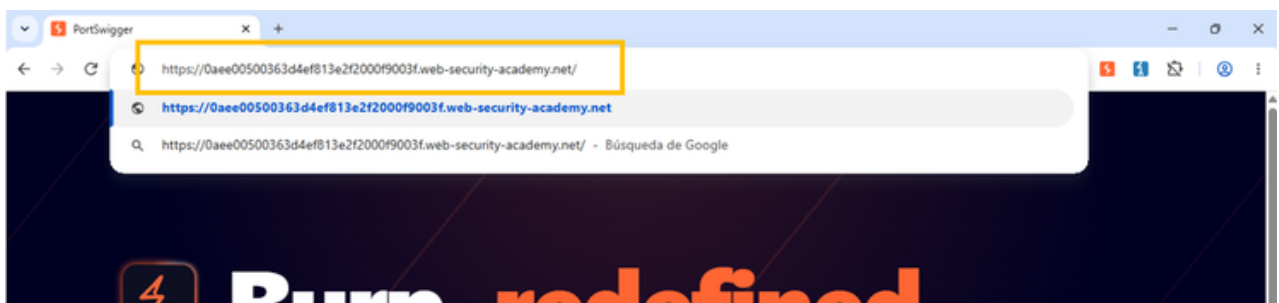
Después de haber ingresado, debemos iniciar BurpSuite, que es en donde estaremos realizando la práctica. Continuando, una vez iniciado BurpSuite, debemos de movernos a la pestaña de Proxy.



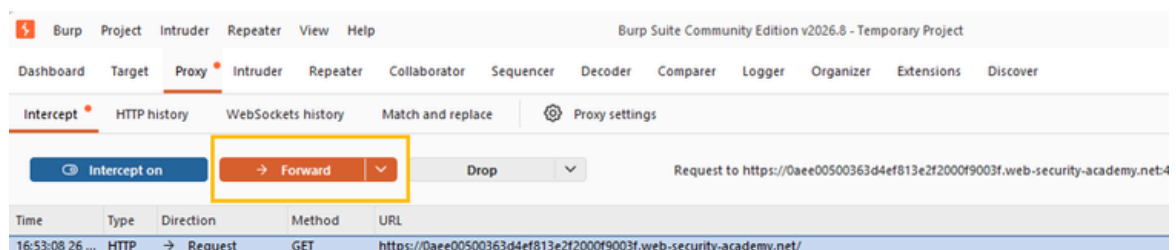
Una vez en la pestaña de **Proxy**, podemos ver que el **Intercept** está apagado, por lo que debemos encenderlo, para así dar clic en **Open Browser**.



Una vez abierto el navegador deberemos ingresar el enlace de la práctica.

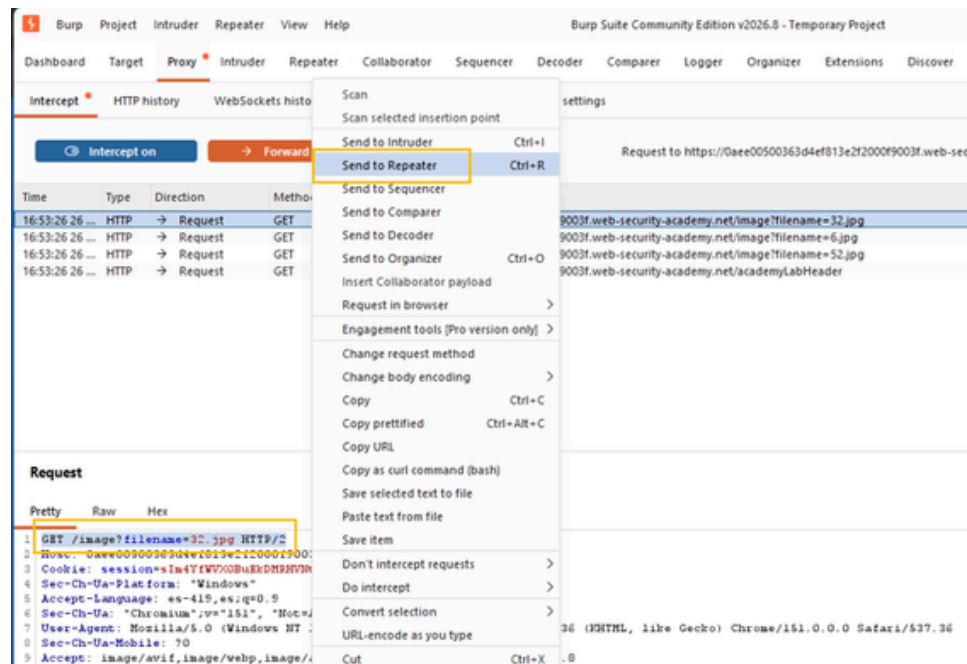


Ya que ingresamos el enlace, nos moveremos a la ventana de BurpSuite, en donde veremos todas las acciones que se llegan hacer para que la página cargue. Para poder realizar la práctica debemos de dar clic en **Forward** hasta que en las peticiones nos aparezca la ruta de una imagen.

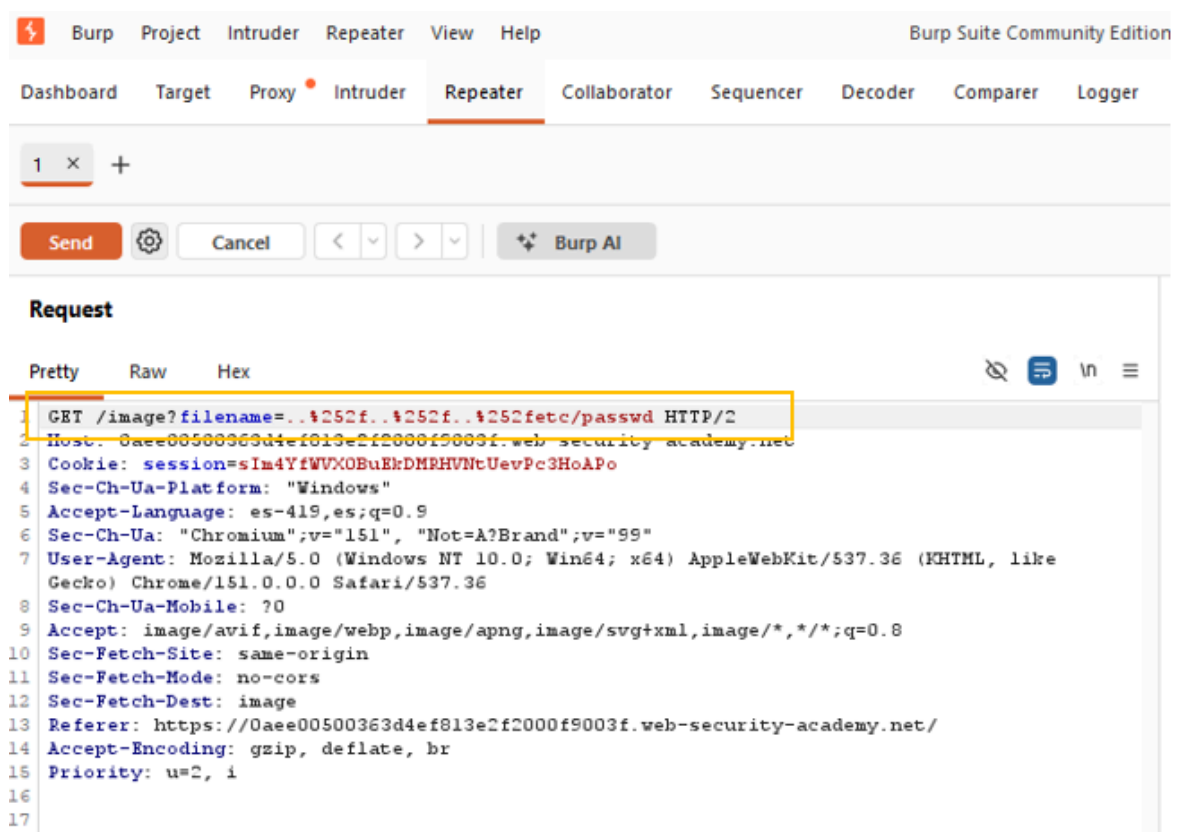


Request

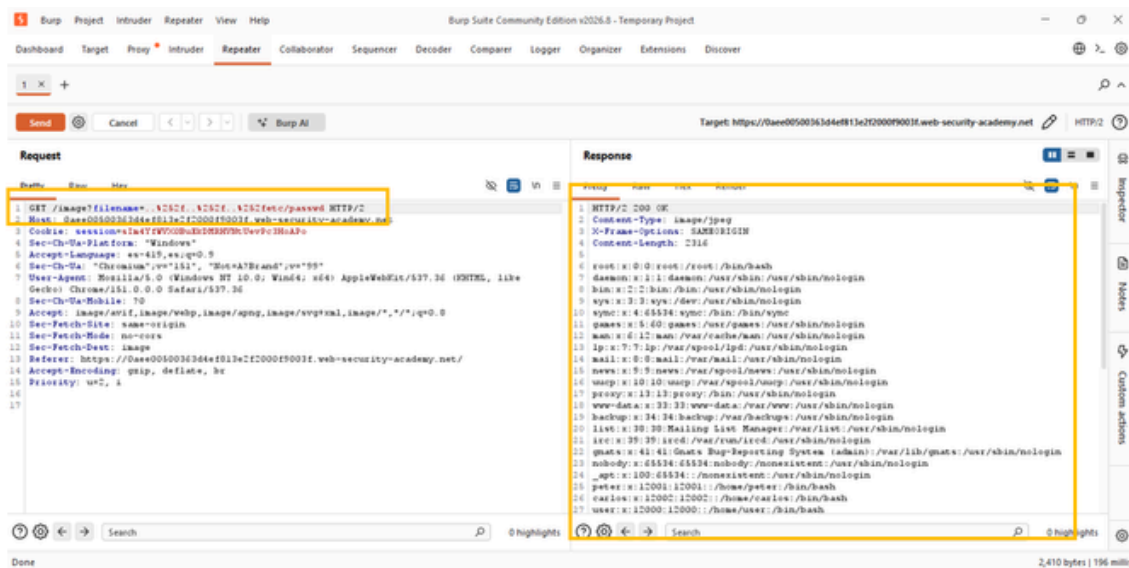
Ya que ubicamos el endpoint, debemos seleccionarlo y dar clic derecho sobre lo seleccionado, para que se nos despliegue un menú en el cual se mostrarán diferentes opciones, nosotros en este caso seleccionaremos la opción de **Send to Repeater** (Enviar al Repetidor).



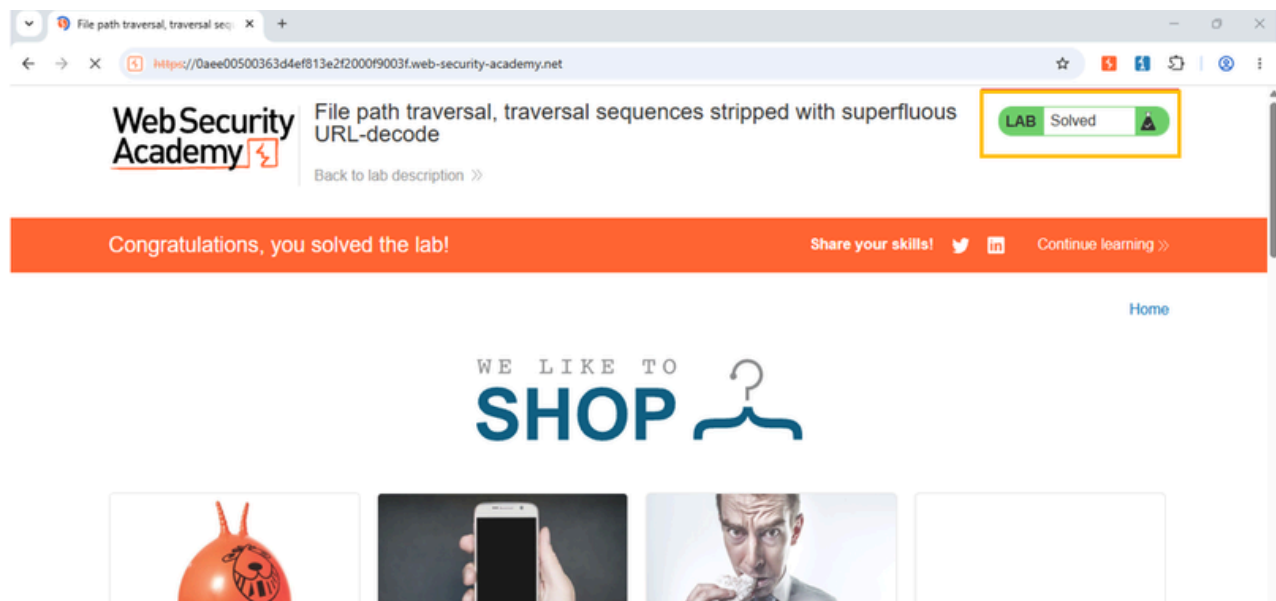
Después de haber mandado esta intrucción al repetidor, debemos movernos a la pestaña de **Repeater**, en donde cambiaremos la ruta para que se pueda abrir la imagen. Nosotros, cambiaremos esa ruta a la siguiente: **GET /image?filename=..%252f..%252f..%252fetc/passwd**. Esto apra poder visualizar lo que se encuentra en ese directorio, pero para eso debemos dar clic en **Send**.



Una vez que dimos clic en **Send**, se deberá mostrar el contenido del directorio en el apartado de **Response**.



Al poder observar esta información, esto nos indica que nuestra práctica está terminada de manera satisfactoria. Pero podemos confirmar esto al irnos a la página de la práctica, en donde se deberá ver que ya la resolvimos.



Explicación del Payload

El payload utilizado es:

..%252f..%252f..%252fetc/passwd

Este payload utiliza doble codificación URL para evadir el filtro de Path Traversal de la aplicación.

- **..** permite retroceder un directorio.
- **%25** representa el carácter %.
- **%252f** después de una primera decodificación se convierte en **%2f**.
- **%2f** después de una segunda decodificación se convierte en **/**.
- **etc/passwd** especifica el archivo que se intenta consultar.

Al repetir esta secuencia: **..%252f..%252f..%252fetc/passwd**, el servidor termina interpretándola como: **../..../etc/passwd**.

De esta manera, la aplicación puede salir del directorio destinado a las imágenes y acceder al archivo **/etc/passwd**.

Mitigación Recomendada

La principal medida es no confiar en la entrada proporcionada por el usuario y evitar que el usuario controle directamente las rutas de archivos.

Se recomienda:

1. Validar y normalizar la ruta antes de utilizarla.
2. Decodificar la entrada completamente antes de realizar las validaciones, evitando que una doble codificación pueda evadir los filtros.
3. Utilizar una lista blanca de archivos permitidos, por ejemplo, identificadores de imágenes en lugar de aceptar rutas directamente.
4. Comprobar que la ruta final permanezca dentro del directorio autorizado.
5. Evitar concatenar directamente la entrada del usuario con rutas del sistema.
6. Aplicar permisos mínimos al usuario que ejecuta la aplicación para limitar el acceso a archivos sensibles.